

LoBeMo

Auditoría · Pentesting · Hardening · Análisis Forense · Capacitaciones · Consultoría

INFORME DE EVALUACIÓN INTEGRAL DE SEGURIDAD

Sistema de Gestión de Ventas — Mueblería Centro Hogar

Cliente evaluado:	Mueblería Centro Hogar (caso de estudio — TFI, Tecnicatura Universitaria en Programación, UTN FRT)
Sistema analizado:	Sistema de Gestión de Ventas Centro Hogar (React 19 + Node.js/Express + MySQL 8)
Tipo de evaluación:	Evaluación documental de seguridad (sin ejecución de pruebas de intrusión reales)
Consultora:	LoBeMo — Servicios de Seguridad Informática
Fecha del informe:	Septiembre de 2026
Clasificación:	Confidencial — uso académico

Nota metodológica: este informe fue elaborado como ejercicio académico integrador. LoBeMo y Centro Hogar son proyectos independientes desarrollados en el marco de trabajos finales de la Tecnicatura Universitaria en Programación (UTN FRT). El análisis se basa exclusivamente en la documentación técnica y funcional entregada por el equipo de Centro Hogar (carpeta final, manual técnico, guía de exposición y documentación de arquitectura); no se ejecutaron pruebas de intrusión, escaneos ni accesos reales sobre ningún sistema en funcionamiento.

Índice

Resumen Ejecutivo

Alcance y Metodología

- 1. Auditoría de Seguridad**
- 2. Pentesting Web (Análisis de Vectores a Nivel Documental)**
- 3. Hardening de Sistemas**
- 4. Análisis Forense**
- 5. Capacitaciones**
- 6. Consultoría Estratégica**

Conclusiones Generales

Anexo — Fuentes Documentales Consultadas

Resumen Ejecutivo

LoBeMo fue convocada para realizar una evaluación integral de seguridad sobre el Sistema de Gestión de Ventas desarrollado para Mueblería Centro Hogar, aplicando su metodología de seis servicios: auditoría de seguridad, pentesting web, hardening de sistemas, análisis forense, capacitaciones y consultoría estratégica. El presente documento consolida los resultados de las seis líneas de trabajo en un único informe, tal como LoBeMo entrega sus evaluaciones a clientes reales.

El sistema evaluado es una aplicación web full-stack (React 19 en el frontend, Node.js/Express en el backend y MySQL 8 como motor de base de datos) que centraliza la gestión de clientes, productos, ventas, inventario, usuarios y reportes de una mueblería. La documentación entregada por el equipo desarrollador es de buena calidad técnica y evidencia la aplicación de numerosas prácticas de seguridad reconocidas: autenticación mediante JWT, contraseñas cifradas con bcrypt, control de acceso basado en roles, validación de datos con Zod, protección de cabeceras HTTP con Helmet, límite de solicitudes (rate limiting) reforzado en el login y consultas parametrizadas que evitan inyección SQL.

No obstante, el análisis documental identificó diez hallazgos que conviene atender antes de considerar el sistema apto para un entorno de producción real, distribuidos de la siguiente manera:

Severidad Alta	Severidad Media	Severidad Baja
4 hallazgos	5 hallazgos	1 hallazgo

Los hallazgos de severidad alta están vinculados al uso de un usuario de base de datos con privilegios de superusuario, la ausencia de una tabla de auditoría de seguridad transversal, la falta de especificación de cifrado en tránsito (HTTPS/TLS) para producción, y la ausencia de una política de privacidad para los datos personales que el sistema almacena. Ninguno de estos hallazgos invalida el trabajo académico realizado —de hecho, varios de ellos ya están anticipados por el propio equipo de Centro Hogar como “mejoras futuras”—, pero sí marcan la diferencia entre un sistema que funciona correctamente en un entorno controlado de tesis y uno preparado para operar con datos reales de clientes.

“El sistema demuestra una base de seguridad sólida para el nivel académico exigido; las brechas identificadas son propias de la etapa de ‘producto mínimo viable’ y siguen, en su mayoría, la misma hoja de ruta que el equipo ya se había trazado.”

Alcance y Metodología

Objeto de la evaluación

El objeto de esta evaluación es el Sistema de Gestión de Ventas de Mueblería Centro Hogar, un proyecto académico (Trabajo Final Integrador) desarrollado por un equipo ajeno a LoBeMo en el marco de la Tecnicatura Universitaria en Programación de la UTN Facultad Regional Tucumán. LoBeMo lo toma como caso de estudio ficticio para demostrar la aplicación de sus seis servicios sobre un cliente real de alcance acotado (una mueblería de una sola sucursal).

Fuentes documentales analizadas

El análisis se realizó exclusivamente sobre la documentación provista por el equipo de Centro Hogar, sin acceso al código fuente completo ni al sistema en ejecución:

- Carpeta Final del TFI: resumen ejecutivo, estado del arte, reglas de negocio, requerimientos funcionales y no funcionales, modelo entidad-relación, plan de trabajo y conclusiones.
- Manual Técnico del sistema: arquitectura, diccionario de datos, tecnologías utilizadas, seguridad implementada y capturas de pantalla de los módulos.
- Guía de exposición: explicación funcional en profundidad de los módulos de Reportes, Copias de seguridad y Seguridad de cuentas/aplicación.
- Documentación de arquitectura (DOCUMENTACION.md) y README del repositorio: estructura de carpetas, endpoints, variables de entorno, diagramas de flujo y modelo de datos.

Metodología

Se trata de una evaluación documental (“caja blanca sobre papel”): LoBeMo no ejecutó escaneos, intentos de intrusión, ni accedió a ningún entorno en funcionamiento. Cada uno de los seis servicios se aplicó de la siguiente manera:

- Auditoría de Seguridad: revisión de la arquitectura, controles de acceso y prácticas declaradas contra marcos de referencia como OWASP ASVS.
- Pentesting Web: identificación de vectores de ataque plausibles sobre la superficie descrita (endpoints, autenticación, roles), sin explotación real.
- Hardening de Sistemas: comparación de la configuración documentada contra lineamientos tipo CIS Benchmarks para Node.js/Express y MySQL.
- Análisis Forense: evaluación de la capacidad del sistema para reconstruir incidentes a partir de los registros y trazas que genera.
- Capacitaciones: revisión de los contenidos de capacitación ya previstos y detección de brechas desde la óptica de seguridad.
- Consultoría Estratégica: análisis de cumplimiento normativo y propuesta de hoja de ruta priorizada.

Cada hallazgo se identifica con un código (H1 a H10) y una severidad (Alta, Media o Baja) asignada según el impacto potencial sobre la confidencialidad, integridad o disponibilidad de la información, y la probabilidad de explotación dado el contexto de una mueblería de una sola sucursal.

1. Auditoría de Seguridad

La auditoría evaluó la arquitectura documentada, los procesos de autenticación y autorización, y las prácticas de gestión de la información declaradas por el equipo de Centro Hogar, comparándolas contra los principios de OWASP ASVS (Application Security Verification Standard) en su nivel 1.

1.1 Arquitectura y separación de responsabilidades

El sistema sigue una arquitectura de tres capas correctamente separadas: el frontend (React SPA) nunca accede a la base de datos de forma directa, sino que toda operación pasa por la API REST del backend, que a su vez es la única capa con acceso a MySQL. Esta separación es una buena práctica que reduce la superficie de ataque expuesta al navegador y centraliza la validación de reglas de negocio en un único punto auditable.

El backend está organizado en capas (Controllers → Services → acceso a datos), con middlewares dedicados para autenticación, control de roles y manejo de errores. Esta modularidad facilita auditorías futuras, ya que cada responsabilidad de seguridad (verificar token, verificar rol, sanear errores) vive en un componente identificable y no está dispersa en la lógica de negocio.

1.2 Autenticación y gestión de contraseñas

Las contraseñas se almacenan cifradas con bcrypt (factor de costo 12), un algoritmo de hashing adaptativo recomendado por OWASP para credenciales, resistente a ataques de fuerza bruta por su costo computacional configurable. El acceso al sistema se realiza mediante JSON Web Tokens firmados, con una expiración de 8 horas —un valor razonable que equilibra usabilidad (no forzar reautenticación constante) con exposición ante robo de sesión.

Sin embargo, la política de contraseñas documentada se limita a un largo mínimo validado por Zod, sin exigencias de complejidad ni verificación contra listas de contraseñas filtradas (hallazgo H5). Tampoco existe un mecanismo de revocación de tokens del lado del servidor: el “cierre de sesión” invalida el token únicamente en el navegador del usuario, por lo que un token robado sigue siendo válido hasta su vencimiento natural (hallazgo H3).

1.3 Control de acceso basado en roles

El sistema implementa tres roles —administrador, encargado de stock y vendedor— con una matriz de permisos explícita y consistente en toda la documentación revisada:

Sección	Administrador	Encargado de stock	Vendedor
Dashboard	Acceso	Acceso	Acceso
Clientes	Lectura + escritura	Lectura	Lectura
Productos	Lectura + escritura	Lectura + escritura	Lectura
Ventas	Todas	Todas	Solo propias
Reportes	Acceso	Acceso	Sin acceso
Usuarios	Acceso	Sin acceso	Sin acceso
Ajustes / Backups	Acceso	Acceso	Sin acceso

La matriz está bien diseñada según el principio de mínimo privilegio a nivel funcional: el vendedor, que es el rol con mayor exposición (trato directo con clientes y manejo de efectivo/pagos), es también el más restringido. El punto

débil es que esta matriz depende enteramente de que cada endpoint del backend valide el rol correctamente; la documentación no aporta evidencia de pruebas automatizadas que verifiquen esa consistencia endpoint por endpoint.

1.4 Gestión de secretos y configuración

Las credenciales de base de datos y la clave de firma de los JWT se gestionan mediante variables de entorno (.env) excluidas del control de versiones, lo cual es correcto. Sin embargo, la configuración de referencia utiliza el usuario “root” de MySQL por defecto, sin distinguir entre un entorno de desarrollo (aceptable) y uno de producción, donde debería usarse un usuario de aplicación con privilegios acotados (hallazgo H1).

1.5 Registro de operaciones críticas

El requerimiento RF23 (“el sistema deberá registrar auditorías de operaciones críticas”) se satisface parcialmente: la tabla movimientos_stock registra usuario, cantidad, motivo y fecha para cada movimiento de inventario, lo cual es un buen ejemplo de trazabilidad focalizada. Pero no existe una tabla de auditoría equivalente para otros eventos críticos mencionados implícitamente en los requerimientos no funcionales de seguridad, como inicios de sesión, cambios de rol de usuario, o descargas de backup (hallazgo H2).

Hallazgos de Auditoría

ID	Hallazgo	Severidad	Recomendación
H1	El backend se conecta a MySQL con el usuario “root” por defecto (DB_USER=root), sin un usuario de aplicación de privilegios acotados.	Alta	Crear un usuario MySQL exclusivo para la aplicación con permisos limitados (SELECT/INSERT/UPDATE/DELETE solo sobre la base centro_hogar), revocando privilegios administrativos.
H2	La única tabla de auditoría documentada (movimientos_stock) cubre altas y bajas de inventario, pero no existe un registro general de eventos de seguridad (inicios de sesión, cambios de rol, exportaciones de backup, intentos fallidos).	Alta	Implementar una tabla audit_log transversal que registre usuario, acción, entidad afectada, IP y resultado (éxito/fallo) para todo evento sensible, no solo movimientos de stock.
H3	El token JWT no cuenta con mecanismo de revocación del lado del servidor; el cierre de sesión (“logout”) invalida el token únicamente en el cliente.	Media	Incorporar una lista de revocación (denylist) o un identificador de sesión validado contra la base, de forma que un token robado pueda invalidarse antes de su vencimiento natural (8 h).
H5	La validación de contraseñas (Zod) exige un largo mínimo, pero no se documentan requisitos de complejidad (mayúsculas, números, símbolos) ni verificación contra contraseñas filtradas.	Media	Definir una política de contraseñas alineada a NIST SP 800-63B (longitud mínima 12, sin composición forzada pero con verificación contra listas de contraseñas comprometidas).

2. Pentesting Web (Análisis de Vectores a Nivel Documental)

Esta sección identifica vectores de ataque plausibles sobre la superficie expuesta por el sistema, a partir exclusivamente de lo descrito en la documentación técnica (endpoints, mecanismos de autenticación y protecciones declaradas). No se ejecutó ningún escaneo, solicitud HTTP real ni intento de explotación contra un sistema en funcionamiento.

2.1 Superficie de ataque identificada

La API REST expone los siguientes grupos de endpoints, según el documento de arquitectura: `/api/auth`, `/api/usuarios`, `/api/categorias`, `/api/productos`, `/api/clientes`, `/api/ventas`, `/api/reportes` (incluyendo `/api/reportes/backup`) y `/api/admin`. Todos, salvo el login, requieren un token JWT válido en la cabecera Authorization.

2.2 Vectores analizados y mitigaciones documentadas

Vector de ataque	Mitigación documentada	Riesgo residual
Fuerza bruta sobre <code>/api/auth/login</code>	Rate limiting reforzado: 8 intentos cada 15 minutos	Bajo si el límite es por cuenta e IP combinadas; no se documenta si además existe bloqueo progresivo o CAPTCHA
Inyección SQL en formularios (clientes, productos, ventas)	Consultas parametrizadas (prepared statements) en toda la capa de acceso a datos	Bajo, siempre que la práctica se aplique de forma uniforme en el 100% de las consultas, incluidos los reportes con filtros dinámicos
Manipulación de roles / escalado de privilegios (IDOR)	Middleware de roles (soloAdmin, adminOStock) valida el JWT en cada ruta protegida	Medio: no se documentan pruebas que confirmen que un vendedor no pueda acceder a ventas de otro vendedor manipulando el ID en la URL
Reutilización de un token robado	Expiración de 8 horas	Medio: al no existir revocación server-side (H3), el token sigue siendo válido durante toda su vigencia aunque el usuario cierre sesión
Ataques de cabecera / clickjacking / MIME sniffing	Helmet aplica cabeceras de seguridad HTTP por defecto	Bajo, cabeceras estándar cubren la mayoría de los vectores del lado del navegador
Solicitudes cross-origin no autorizadas (CSRF/CORS)	CORS restringido al origen del frontend configurado	Bajo-Medio: no se documenta si además existe protección CSRF explícita, aunque el uso de JWT en cabecera (no en cookie) reduce el riesgo clásico de CSRF
Exfiltración masiva de datos vía backup	Endpoint restringido al rol administrador	Bajo-Medio: si una cuenta admin es comprometida, el endpoint de backup permite descargar toda la base en una sola solicitud (H9)

2.3 Observación sobre el script de recuperación de emergencia

La documentación menciona un script de línea de comandos (reset-password) para restablecer la contraseña del administrador cuando no hay otro admin disponible. Este mecanismo es una buena práctica de continuidad operativa, pero constituye una vía de acceso privilegiado que depende enteramente de la seguridad del servidor donde corre: cualquier persona con acceso físico o remoto (SSH) al servidor podría tomar control total del sistema. Se recomienda documentar y restringir explícitamente quién tiene ese acceso y registrar su uso.

Hallazgos de Pentesting

ID	Hallazgo	Severidad	Recomendación
H3	El token JWT no cuenta con mecanismo de revocación del lado del servidor; el cierre de sesión ("logout") invalida el token únicamente en el cliente.	Media	Incorporar una lista de revocación (denylist) o un identificador de sesión validado contra la base, de forma que un token robado pueda invalidarse antes de su vencimiento natural (8 h).
H9	El límite de solicitudes (rate limiting) está descrito como una protección general reforzada en el login, sin mención de un límite específico para los endpoints de exportación masiva (/api/reportes/backup).	Baja	Aplicar un límite dedicado y más estricto sobre los endpoints de backup y exportación, dado que concentran toda la información del negocio en una sola respuesta.

3. Hardening de Sistemas

El servicio de hardening compara la configuración documentada del servidor de aplicación (Node.js/Express) y del motor de base de datos (MySQL 8) contra lineamientos de referencia inspirados en los CIS Benchmarks para ambas tecnologías.

3.1 Servidor de aplicación (Node.js / Express)

Control tipo CIS	Estado documentado	Evaluación
Cabeceras HTTP de seguridad	Helmet habilitado por defecto	Cumple
Restricción de origen (CORS)	CORS limitado a la URL del frontend configurada en FRONTEND_URL	Cumple
Límite de tasa de solicitudes	express-rate-limit global, reforzado en login	Cumple
Validación de entrada en el servidor	Zod valida el body de cada request en el controlador	Cumple
Manejo uniforme de errores sin fuga de información	error.middleware traduce errores de MySQL a códigos HTTP genéricos	Cumple
Gestión de secretos fuera del código fuente	Variables de entorno en .env, excluido del repositorio	Cumple
Cifrado en tránsito (TLS)	No documentado para producción; instalación descrita sobre HTTP en localhost	No cumple (H4)
Actualización periódica de dependencias	No se documenta proceso de escaneo de vulnerabilidades (npm audit / Dependabot)	No cumple (H7)

3.2 Base de datos (MySQL 8)

Control tipo CIS	Estado documentado	Evaluación
Usuario de aplicación con privilegios mínimos	El .env de referencia usa DB_USER=root	No cumple (H1)
Contraseña de administrador de base de datos	DB_PASSWORD vacío por defecto en el entorno de instalación local	Aceptable solo en desarrollo; requiere endurecerse en producción
Cifrado en reposo	No documentado	Sin evidencia — recomendar evaluación
Integridad referencial y restricciones	Claves foráneas con ON UPDATE CASCADE / ON DELETE RESTRICT / SET NULL según corresponda	Cumple
Normalización y columnas calculadas	Modelo en Tercera Forma Normal, con columnas GENERATED STORED para totales	Cumple — reduce el riesgo de inconsistencias manipuladas desde la aplicación

Control tipo CIS	Estado documentado	Evaluación
Trazabilidad de cambios de stock	Tabla movimientos_stock con usuario, motivo y fecha	Cumple parcialmente (ver Auditoría, H2)

3.3 Fortalezas destacables

Vale resaltar que el diseño de base de datos incorpora buenas prácticas de hardening a nivel de esquema que exceden lo habitual en un proyecto académico: uso de columnas GENERATED STORED para evitar que el total de una venta pueda insertarse manipulado desde la aplicación, un trigger que numera las ventas de forma atómica, y una transacción explícita (BEGIN/COMMIT/ROLLBACK) que garantiza que el descuento de stock y el registro de la venta ocurran de forma atómica: si falla cualquier paso, no queda stock descontado sin una venta asociada.

Hallazgos de Hardening

ID	Hallazgo	Severidad	Recomendación
H1	El backend se conecta a MySQL con el usuario “root” por defecto (DB_USER=root), sin un usuario de aplicación de privilegios acotados.	Alta	Crear un usuario MySQL exclusivo para la aplicación con permisos limitados (SELECT/INSERT/UPDATE/DELETE solo sobre la base centro_hogar), revocando privilegios administrativos.
H4	La documentación no especifica el uso de HTTPS/TLS para el entorno de producción; las instrucciones de instalación describen tráfico HTTP en localhost.	Alta	Exigir TLS 1.2+ en cualquier despliegue fuera del entorno de desarrollo, con redirección forzada de HTTP a HTTPS y HSTS habilitado vía Helmet.
H7	No se documenta un proceso periódico de actualización de dependencias (npm audit, Dependabot o similar) para el stack Node.js/React.	Media	Incorporar escaneo automático de dependencias en cada build y una cadencia mensual de revisión de vulnerabilidades conocidas (CVE).

4. Análisis Forense

El análisis forense evalúa la capacidad del sistema, tal como está documentado, para reconstruir la secuencia de eventos ante un incidente de seguridad o una disputa operativa (por ejemplo, una venta cuestionada o un acceso indebido).

4.1 Fuentes de evidencia disponibles

- Columnas `created_at` / `updated_at` presentes en la mayoría de las tablas (ventas, clientes, productos, usuarios), que permiten reconstruir líneas de tiempo básicas.
- Tabla `movimientos_stock`, que documenta usuario, tipo de movimiento, cantidad, motivo y fecha para cada cambio de inventario — la fuente de evidencia más completa del sistema.
- El trigger de numeración de ventas y las columnas `GENERATED` garantizan que los totales almacenados sean matemáticamente consistentes con sus componentes, lo que facilita detectar manipulación de datos si un total no coincide con lo calculable a partir del detalle.
- La transacción atómica de venta (`BEGIN/COMMIT/ROLLBACK`) asegura que no existan estados intermedios corruptos (por ejemplo, stock descontado sin una venta registrada) que compliquen una reconstrucción.
- El mecanismo de “respaldo automático antes de borrar” en la limpieza de ventas antiguas preserva una copia en Excel de todo lo eliminado, lo cual es una fuente de evidencia valiosa incluso después de un borrado legítimo.

4.2 Brechas identificadas

El principal punto débil desde la óptica forense es la ausencia de una tabla de auditoría de seguridad general (ya señalada como hallazgo H2 en la Auditoría). Concretamente, la documentación no evidencia registro de:

- Inicios de sesión exitosos y fallidos, con marca de tiempo e idealmente dirección IP de origen.
- Cambios de rol o de estado (activo/inactivo) de un usuario, y quién los realizó.
- Descargas de backup (quién exportó la base completa y cuándo), un evento especialmente sensible dado que expone todos los datos de clientes.
- Uso del script de emergencia `reset-password`, que al ejecutarse directamente en el servidor queda fuera del alcance de cualquier log de aplicación.

Sin estos registros, ante un incidente (por ejemplo, una sospecha de que un vendedor accedió a datos de clientes fuera de su rol, o que una cuenta fue comprometida) el equipo de Centro Hogar tendría capacidad limitada para reconstruir qué ocurrió, cuándo y con qué alcance.

4.3 Recomendación

Se recomienda extender el patrón ya utilizado exitosamente en `movimientos_stock` —registro de usuario, acción, motivo y fecha— a una tabla transversal de auditoría de seguridad que cubra, como mínimo, autenticación, gestión de usuarios y exportaciones de datos. Esta única mejora resuelve simultáneamente el hallazgo de auditoría (H2) y la brecha forense aquí descripta.

Hallazgo de Análisis Forense

ID	Hallazgo	Severidad	Recomendación
H2	La única tabla de auditoría documentada (<code>movimientos_stock</code>) cubre altas y bajas de inventario, pero no existe un registro general de eventos de seguridad (inicios de sesión, cambios	Alta	Implementar una tabla <code>audit_log</code> transversal que registre usuario, acción, entidad afectada, IP y resultado (éxito/fallo)

ID	Hallazgo	Severidad	Recomendación
	de rol, exportaciones de backup, intentos fallidos).		para todo evento sensible, no solo movimientos de stock.

5. Capacitaciones

El manual técnico y la guía de exposición documentan que el equipo de Centro Hogar ya realizó una capacitación a los usuarios finales (administradores, vendedores y encargados de stock) sobre el uso funcional del sistema: registro de ventas, gestión de clientes, control de inventario, generación de reportes, gestión de usuarios y copias de seguridad. Esta es una buena práctica que facilita la adopción del sistema y reduce errores operativos.

5.1 Brecha identificada: capacitación funcional vs. capacitación en seguridad

La capacitación documentada es enteramente funcional; no se menciona ningún contenido específico de seguridad de la información dirigido a los usuarios finales, a pesar de que estos manipulan a diario datos personales de clientes (DNI, teléfono, dirección, email) y, en el caso del administrador, credenciales de otros usuarios y el backup completo del negocio.

5.2 Propuesta de contenidos por rol

Público	Contenido ya cubierto	Contenido a incorporar (seguridad)
Vendedor	Registro de ventas, consulta de catálogo, historial de clientes	Manejo responsable de datos de clientes; reconocimiento de intentos de ingeniería social; qué hacer ante sospecha de acceso indebido a su cuenta
Encargado de stock	Gestión de productos y categorías, reportes, ajustes	Buenas prácticas de contraseñas; criterio para decidir cuándo escalar una alerta al administrador
Administrador	Gestión de usuarios, backups, limpieza de ventas antiguas	Gestión segura de backups (dónde y cómo almacenarlos), uso responsable del script de emergencia, política de contraseñas y 2FA, procedimiento ante incidentes

5.3 Formato sugerido

Dado que la empresa opera con una única sucursal y un equipo reducido, LoBeMo recomienda un módulo breve (una a dos horas) integrado a la capacitación funcional ya prevista, en lugar de una instancia separada, para maximizar la asistencia y minimizar la interrupción operativa. El contenido de seguridad debe reforzarse cada vez que se incorpore un nuevo usuario al sistema, particularmente en los roles de administrador y encargado de stock.

Hallazgo de Capacitación

ID	Hallazgo	Severidad	Recomendación
H10	La capacitación documentada para los usuarios del sistema es exclusivamente funcional (cómo registrar ventas, generar reportes, etc.); no incluye contenidos de seguridad de la información.	Media	Sumar un módulo de concientización en seguridad (contraseñas, phishing, manejo de datos de clientes) a la capacitación ya prevista para los tres roles.

6. Consultoría Estratégica

6.1 Cumplimiento normativo

El sistema recolecta y almacena datos personales de clientes (nombre, apellido, DNI, teléfono, dirección, email) y de empleados (usuarios del sistema), lo que lo sitúa dentro del alcance de la Ley N.º 25.326 de Protección de Datos Personales de la República Argentina. La documentación relevada no menciona una política de privacidad, una base legal declarada para el tratamiento de estos datos, plazos de conservación, ni un procedimiento para que un cliente ejerza sus derechos de acceso, rectificación, actualización o supresión (derechos ARCO).

Esto no implica necesariamente un incumplimiento deliberado —es habitual que un proyecto académico priorice la funcionalidad técnica sobre el marco legal—, pero si Centro Hogar fuera una empresa real, este vacío documental sería el hallazgo de mayor exposición legal de todo el informe (hallazgo H8).

6.2 Alineación con la hoja de ruta ya prevista por el equipo

Es importante destacar que varias de las recomendaciones de LoBeMo no son ajenas al proyecto: el propio equipo de Centro Hogar ya identificó como “mejoras a futuro” puntos que se cruzan directamente con hallazgos de este informe, como la incorporación de pruebas automatizadas, integración continua (CI/CD), migración a contenedores Docker y soporte multi-sucursal. La consultoría de LoBeMo puede leerse como un complemento de seguridad a esa misma hoja de ruta, no como una hoja de ruta alternativa.

6.3 Hoja de ruta priorizada

Plazo	Acción recomendada	Hallazgo(s) asociado(s)
Corto plazo (0-3 meses)	Crear usuario de base de datos con privilegios mínimos para la aplicación	H1
Corto plazo (0-3 meses)	Habilitar HTTPS/TLS en cualquier despliegue fuera de desarrollo	H4
Corto plazo (0-3 meses)	Definir y documentar una política de contraseñas y sumar el módulo de capacitación en seguridad	H5, H10
Mediano plazo (3-6 meses)	Implementar tabla de auditoría de seguridad transversal (login, roles, backups)	H2
Mediano plazo (3-6 meses)	Redactar política de privacidad y designar responsable de tratamiento de datos (Ley 25.326)	H8
Mediano plazo (3-6 meses)	Incorporar revocación de tokens JWT y evaluar 2FA para administrador	H3, H6
Mediano plazo (3-6 meses)	Automatizar el escaneo de dependencias (npm audit / Dependabot) en el flujo de desarrollo	H7
Largo plazo (6-12 meses)	Extender 2FA a encargado de stock; endurecer límite de tasa en endpoints de backup	H6, H9
Largo plazo (6-12 meses)	Sumar hardening de seguridad a la migración a Docker y al soporte multi-sucursal ya planificados	H1, H4

6.4 Próximos pasos con LoBeMo

LoBeMo propone acompañar la implementación de esta hoja de ruta con revisiones trimestrales de seguimiento, priorizando siempre los hallazgos de severidad alta del primer trimestre. Cada revisión incluiría una nueva verificación documental (y, cuando el sistema esté desplegado en un entorno accesible, una primera ronda de pentesting real con autorización expresa del cliente) para confirmar que las brechas señaladas fueron efectivamente cerradas.

Conclusiones Generales

El Sistema de Gestión de Ventas de Mueblería Centro Hogar es un desarrollo técnicamente sólido para su contexto académico, con decisiones de arquitectura y seguridad que exceden lo mínimo exigible en un Trabajo Final Integrador: separación clara de capas, autenticación robusta, control de acceso basado en roles bien definido, protección contra los vectores de ataque web más comunes y un diseño de base de datos que privilegia la integridad de la información.

Los diez hallazgos identificados por LoBeMo no cuestionan esa base técnica, sino que marcan la brecha esperable entre un proyecto de tesis evaluado en un entorno controlado y un sistema listo para operar con datos reales de clientes en producción. Cuatro de esos hallazgos —privilegios excesivos del usuario de base de datos, ausencia de auditoría de seguridad transversal, falta de cifrado en tránsito documentado y ausencia de política de privacidad— concentran el riesgo principal y deberían ser la prioridad de cualquier plan de trabajo posterior a la defensa del proyecto.

En síntesis, LoBeMo considera que Centro Hogar cuenta con una base sobre la cual construir un producto seguro, y que la hoja de ruta propuesta en la sección de Consultoría Estratégica permite cerrar esa brecha de forma progresiva y alineada con las mejoras que el propio equipo desarrollador ya se había planteado.

Anexo — Fuentes Documentales Consultadas

- Carpeta_Final.pdf — Trabajo Final Integrador “Sistema de Gestión de Ventas — Mueblería Centro Hogar”, Tecnicatura Universitaria en Programación, UTN Facultad Regional Tucumán (integrantes: Juarez, Alexis; Marquez, Juan; Villarreal, María V.; tutor: Ing. Raúl E. Prado).
- Manual_Tecnico_Sistema_de_gestion_de_ventas_muebleria_centro_hogar.pdf — Manual técnico del sistema, incluyendo anexos de arquitectura, DER y capturas de pantalla.
- GUIA-EXPOSICION (pdf / md) — Guía de exposición para la defensa oral, con foco en Reportes, Copias de seguridad y Seguridad.
- README.md — Documentación de instalación, variables de entorno, credenciales de prueba y matriz de permisos del repositorio del sistema.
- DOCUMENTACION.md / Centro_Hogar.docx — Documentación de arquitectura técnica, estructura de código, endpoints, modelo de datos y decisiones de diseño del proyecto.

Informe elaborado por LoBeMo con fines académicos. No constituye una auditoría de seguridad certificada ni sustituye una prueba de penetración real ejecutada con autorización expresa sobre un sistema en producción.